

Request for Information (RFI) and Request for Proposal (RFP) are part of a deliberate and intentional process associated with engaging an MSSP. This type of evaluation should be completed in accordance with the FI's strategic plan and tactical approach to security. For example, the strategic plan should determine what security functions to maintain in-house, whether to contract a sole provider, or split services between providers. The RFI, the initial formal step in selection, must define FI objectives for the service needed. These objectives primarily are to be based on the FI's configuration (OS, security, network, and servers) and security policies. The FI should also consider the MSSP's staffing, certifications, training, transition process, and incident response methodology.

It is essential for the FI to coordinate with the MSSP regarding configuration and staff resources. This will be important not only to initial selection through the RFI/RFP and contracting process, but as the relationship evolves. It is important that the MSSP be a cultural fit with the FI. 3 MSSP specific contract language will require modification to RFIs and RFPs based on the FI and vendor configuration. See subsection, MSSP Engagement Criteria for RFI/RFP examples specific to MSSPs.

Initial Due Diligence

An FI considering an MSSP engagement must perform adequate due diligence to validate that the vendor is capable of managing security services that are aligned with their risk profile. Management should consider performing an onsite visitation to determine if the servicer has the appropriate experience and control environment to meet the FI's needs, how long the MSSP has been in business, the MSSP's staffing, the MSSP's incident response methodology, etc.

When performing an onsite visitation, the FI should determine if the MSSP can ensure the security of their data. Pertinent entity and operating information should be obtained to facilitate the vendor selection process. Discussions with management should focus on the risk elements noted in the risk assessment section with emphasis on determining that the MSSP has the necessary expertise and experience to service the FI and will provide sufficient metrics for the FI to assess compliance with the contract.

The time the MSSP has been operating and if there are any expected changes (e.g., merger, acquisitions, expansion/growth, etc.), that could impact contracted services should be determined. The number of clients the MSSP services and number of FI clients also should be identified. If the MSSP does not have FI clients, it may indicate the vendor is seeking to enter into an unfamiliar business area. Before accepting this risk, the MSSP's familiarity with pertinent regulatory requirements such as GLBA, SOX, and FFIEC guidance must be validated.

When evaluating the MSSP's expertise, the following should be considered:

- Current and unbiased customer testimonials and/or references;
- Use of current monitoring and risk management technologies;
- The MSSPs ability to:

- o Generate timely MIS reporting and incident notification;

- o Maintain confidentiality, integrity, and availability of FI data; and

- Manage prospective services for the defined contract term.

If the MSSP does not perform all services in-house, FIs should determine which services are to be outsourced, the quality of vendor management exercised by the MSSP, and whether the service provider(s) is/are offshore.

To fulfill its duties, an MSSP may be required to install software and/or hardware in an FI's data center. What data will be collected, reviewed, stored, and secured by the MSSP should be defined with established SLAs based on business requirements. The dialog between the MSSP and the FI should focus on identifying services that preserve security.

The initial due diligence process is a key method to determine if an MSSP can provide the necessary services to an FI. Each of the above recommendations should be considered in deciding if the MSSP is viable and has the ability to fulfill the terms of the engagement.

Contracts

In any MSSP arrangement, the contractual expectations and obligations of each party should be clearly defined, understood, monitored, and enforced. FI managers who have a strong understanding of MSSP risks and mitigating controls should be involved in contract development. Legal representatives with the expertise to assess the enforceability and legitimacy of MSSP contract terms should review contract provisions and be included in contract negotiations. The alignment of contract provisions with FI security policies and procedures creates a strong foundation for the development of

comprehensive MSSP agreements.

Although most contract requirements for MSSPs are similar to those of other outsourcing arrangements, FIs should consider the following provisions when developing a formal contract with an MSSP.

Scope of Service

Contract discussion should include:

- Specific services provided, timelines for implementation, and explicit responsibilities of the MSSP and the FI;
- The right to modify existing services performed under the contract;
- The type and frequency of reports available;
- Activities the MSSP is allowed to conduct when operating within the FI network;
- Handling of confidential data;
- Ownership of data generated by proprietary security or third-party monitoring tools owned by the MSSP; and
- Access rights granted to the MSSP as it relates to FI network systems.

Service Level Agreements

Well defined SLAs provide the framework for establishing the expectations and metrics for the effective delivery of service such as levels of availability, performance, or support. When working with MSSPs, attention should be given to the engagement criteria in Appendix A.

Contract Term and Renewal

The role of the MSSP relationship and how the length of the contract integrates with the FI's overall business strategy and objectives should be defined. Long-term contracts may limit flexibility and consideration should be given to whether to accept automatic contract renewal provisions.

Termination

FIs should consider including termination rights for a variety of conditions including material breach, critical performance failure, and material non-performance. Grounds for termination should be clearly defined and agreed on by the FI and service provider. If the contract is terminated for cause, the MSSP should cover damages. The FI's exit strategy should consider post-termination rights including:

- Transfer of data in the FI's preferred format;
- Transfer of FI data or assets from the MSSP and all subcontractors;
- Assistance from the service provider to migrate services in-house or to another provider;
- Right to purchase non-proprietary tools used by the MSSP to provide the services; and
- Timely response to the FI's post-termination requests.

Managing the Relationship

While the initial due diligence is critical to managing the MSSP relationship, ongoing monitoring and oversight is equally important. Risks of the MSSP relationships are generally similar to risks of other outsourcing arrangements that need to be addressed within the FI's vendor management program, but the MSSP relationship has some attributes that may call for a heightened level of (or more targeted) education and training.

Education and Awareness

Effective MSSP oversight requires an FI to maintain adequate in-house technical expertise. This enables the FI to monitor and maintain acceptable risk exposure and confirm the MSSP is fulfilling contractual obligations. Education and awareness for FI employees is necessary to help ensure:

- The MSSP is effectively managing the relevant information security risk;
- Personnel understand the processes, procedures, and protocols of the MSSP, including the use of subcontractors; and

- FI management understands:

- o What data the MSSP is collecting and who has access to the data;

- o Information in audit reports and security testing of the MSSP; and

- o How to measure a successful relationship.

Given the high risk and trust of the relationship, the FI should verify that the MSSP is appropriately managing the contracted security services on its behalf. The following should be addressed in the FIs education and awareness program:

- Training, education, and awareness provided by the MSSP to FI employees;
- Identifying and understanding accountable and responsible parties at the FI and MSSP;
- Maintaining the expertise needed to understand metrics and reporting provided by the MSSP; and
- Training frequency for FI employees.

Contract Performance

FI management should have a monitoring process to attest to the MSSP meeting its contractual obligations. This typically entails reviewing items such as SLAs, Key Performance Indicators (KPIs), Key Risk Indicators (KRIs), security event notification, incident response, and any other metrics relative to performance. These items should be included in MSSP reports, and FIs should perform supplemental monitoring as necessary to evaluate contractual performance.

Ongoing Oversight of MSSP Relationship

The critical services provided by MSSPs require a high level of FI oversight throughout the lifecycle of the contracting relationship. Processes should include maintenance of controls established as part of the initial due diligence, including:

- Reviewing:
 - o MSSP provided MIS reports,
 - o MSSP audit reports, including SSAE 16 and other independent assessment reports, and
 - o Penetration testing and vulnerability assessment test results;
- Performing periodic onsite visitations of the MSSP;
- Monitoring the MSSP's internal risk assessment process; and
- Discussing any concerns related to the above items with MSSP management.

Contingency & Event Planning

Business Continuity Planning

To avoid a gap in service in the event of an MSSP outage, the FI should:

- Review the MSSP's business continuity plans for the ability to provide continuous services to the FI;
- Confirm that MSSPs have tested their business continuity plans at least annually and have forwarded a summary to the FI; and
- Include critical MSSPs in the FI's tabletop exercise or other business continuity testing.

Incident Response

To assess that the FI is fully prepared to respond to incidents, the FI should:

- Develop and maintain an incident response plan which includes a remediation process clearly defining roles and responsibilities between the MSSP and the FI;
- Establish and review processes and procedures to handle communications to and from the MSSP;
- Establish and define event types and response procedures; and
- Include the MSSP in testing of the incident response plan.

Alternative Providers

To prevent gaps in service associated with MSSP failure, the FI should:

- Maintain awareness of alternate providers;
- Develop policies and procedures to outline FI data ownership;

- Have a clear understanding of service provider roles and responsibilities;
- Assess the MSSP for dependencies with critical services; and
- Consider using multiple vendors to provide various MSSP services.

Demarcation of Responsibility

Along with general monitoring and oversight of the MSSP, FIs should have involvement in the operational and policy activities associated with the MSSP. Examples include:

Policy and Procedures

Outsourcing certain security activities does not diminish the need for adequate security policies at the FI. They should coordinate their information security program with the policies, standards, guidelines, and procedures of the MSSP.

Incident Response

The incident response function needs to be coordinated and clearly defined between the FI and MSSP. Notification and escalation requirements regarding incident response should be clearly documented and aligned between the FI and MSSP. The definition of a reportable event should be clear and unambiguous.

Access Controls

Assess controls/methods and audit trails related to the FI's systems, devices, and data being managed by the MSSP.

Physical Security

Typically the MSSP will place devices within the FI (e.g., firewall, IDS, etc.) which the MSSP may own and/or control. FIs should consider appropriate physical security of such

devices regardless of ownership and/or control.

Change Control

There should be a clear process to communicate changes implemented by either the FI or MSSP. Changes can have a material impact on the security environment, and both parties should undergo an adequate change control review. Advanced notification of any changes should be provided whenever possible.

Data Collection/Logging

The FI should maintain awareness of data the MSSP is collecting, how it is stored, and how it is used. The FI should maintain its data or logs separate from other MSSP clients. The MSSP's data collection and security event classification processes should be defined and understood to help in corroborating the integrity of the FI's data and in establishing a more effective log review process.

Metrics and Reporting

The MSSP should provide regular reporting on agreed on performance metrics to the client FI. It is important that qualified FI personnel review these reports to attest that the security controls of MSSPs are operating as expected. Metrics and reporting should include security:

- Events potentially affecting the FI;
- Statistics specific to the FI;
- Intelligence, and;
- Operational statistics and conditions specific to the FI.

Emerging Risks

Cloud computing is an emerging trend in which some of the IT industry's biggest players are investing significant resources. Cloud computing in general is a migration from owned resources to shared resources in which client users receive information technology services on demand from third-party service providers via the Internet "cloud." In cloud environments, a client or customer will relocate their resources such as data, applications, and services to computing facilities outside the corporate firewall, which the end user then accesses via the Internet.

Cloud-based MSSP services may be implemented as part of Internet access services. Examples of "in-the-cloud" services include carrier-based denial of service protection, virtual firewall services, and carrier-provided URL blocking.

When an MSSP offers services that use a cloud computing architecture, the same risks that are specific to non-cloud-based security services apply. However, there are a few additional risk considerations that should be assessed when moving to a cloud computing environment. Areas for FIs to consider when an MSSP uses cloud computing in their managed security services environment include:

- Protecting data in transit to avoid data leakage;
- Securing data at rest so that one data breach within the cloud does not breach the other customer data within the cloud;
- Maintaining compliance with applicable regulatory requirements;
- Complying with foreign government privacy laws when outsourcing is performed offshore;
- Segregating customer data appropriately to comply with audit and legal requirements; and
- Avoiding sharing of authentication credentials to prevent the impersonation of users.

Conclusion

Financial institutions' challenges in dealing with high profile network security breaches, changing technology, malware, system maintenance costs, complexity, and uncertainty surrounding network security have resulted in an increased use of MSSPs. While FIs can leverage the expertise of the MSSP, managing this relationship can be an additional